

1. Define Security Attack with example.

A Security Attack is any action that attempts to compromise the confidentiality, integrity or availability of information or resources.

Example: An attacker steals a user's password by sending a fake email (phishing).

2. What are Security Services?

Security services are services that ensure secure communication and protect systems from attacks. They include:

- Authentication — verifies the identity.
- Access Control — restricts unauthorized access.
- Confidentiality — protects data from disclosure.
- Integrity — ensures data is accurate and unaltered.
- Non-repudiation — prevents denial of actions.
- Availability — ensures services/resources are available.

3. Explain CIA triad (Confidentiality, Integrity, Availability).

- Confidentiality: Ensures information is accessible only to authorized persons.
- Integrity: Ensures information is accurate, complete and not modified by unauthorized persons.
- Availability: Ensures systems and data are available to authorized users when needed.

4. Difference between active and passive attacks.

Feature	Active Attack	Passive Attack
Goal	To alter, modify or destroy data or resources.	To monitor or observe data without changing it.
Examples	DOS, Malware, Data modification, Spoofing.	Sniffing, Traffic analysis, Eavesdropping.
Detectability	Easily detectable.	Difficult to detect.
Impact	Affects system resources.	No direct impact on resources.

5. What is Malware? List types.

Malware (Malicious Software) is software designed to harm, exploit or gain unauthorized access to a system. Types: Virus, Worm, Trojan Horse, Ransomware, Spyware, Adware, Rootkit, Keylogger, Bot.

6. Difference between Virus and Worm.

Feature	Virus	Worm
Definition	Attaches itself to host file/program.	Independent program.
Spread	Needs user action to spread.	Spreads automatically over network.
Effect	Corrupts files, slows system.	Consumes network resources.
Replication	Requires host.	Does not require host.
Example	Melissa, CIH	Conficker, Blaster

7. What is a Trojan Horse?

A Trojan Horse is a type of malware that appears to be useful or legitimate software but performs malicious activities in the background once installed.

8. Define Botnet.

A Botnet is a group of infected computers (bots) controlled remotely by an attacker (botmaster) to perform malicious activities such as sending spam, launching attacks, etc.

9. What is Cryptanalysis?

Cryptanalysis is the study of techniques for breaking cryptographic systems and recovering plaintext or secret keys without knowing the key.

10. Define Cryptography.

Cryptography is the art and science of securing information by converting it into unreadable form (ciphertext) using algorithms and keys so that only authorized parties can read it.

11. Difference between Symmetric and Asymmetric encryption.

Feature	Symmetric Encryption	Asymmetric Encryption
Keys	Same secret key used for encryption and decryption.	Pair of keys: Public key for encryption, Private key for decryption.
Key Distribution	Difficult and less secure.	Easy, public key can be shared.
Speed	Faster.	Slower.
Security	Less secure.	More secure.
Examples	AES, DES	RSA, ECC

12. What is DES?

DES (Data Encryption Standard) is a symmetric block cipher that uses a 56-bit key to encrypt 64-bit data in blocks.

13. Why is DES considered weak?

- Uses short key length (56-bit) — vulnerable to brute force attack.
- Small key space (2^{56}) — can be broken with modern computers.
- Advances in computing power make it insecure.
- Vulnerable to certain cryptanalytic attacks.

14. What is AES?

AES (Advanced Encryption Standard) is a symmetric block cipher that uses 128, 192 or 256-bit keys to encrypt 128-bit data in blocks. It is more secure and faster than DES.

15. List AES transformations.

AES uses the following transformations in each round:

1. SubBytes — Non-linear byte substitution.
2. ShiftRows — Row-wise cyclic shift.
3. MixColumns — Column mixing using linear transformation.
4. AddRoundKey — XOR with round key.

16. Define Block Cipher and Stream Cipher.

Block Cipher: Encrypts data in fixed-size blocks (e.g., 64 or 128 bits) at a time. Examples: AES, DES.

Stream Cipher: Encrypts data one bit or byte at a time as a stream. Examples: RC4, A5/1.

17. What is Key Expansion?

Key Expansion is the process of generating a set of round keys from the original secret key using an algorithm. These round keys are used in each round of encryption.

18. Define RSA algorithm.

RSA is an asymmetric cryptographic algorithm based on number theory. It involves:

1. Key Generation — generate public and private keys.
2. Encryption — encrypt data using public key.
3. Decryption — decrypt data using private key.

19. What is Public Key Cryptography?

Public Key Cryptography uses a pair of keys: a public key (shared with everyone) for encryption and a private key (kept secret) for decryption. It solves the key distribution problem of symmetric encryption.

1. Difference between SSL and TLS.

Feature	SSL (Secure Sockets Layer)	TLS (Transport Layer Security)
Full Form	Secure Sockets Layer	Transport Layer Security
Developed by	Netscape	IETF
Purpose	To provide secure communication over a network.	To provide secure communication over a network.
Security	Less secure (older protocol).	More secure (improved security).
Current Status	Deprecated	Widely used
Latest Version	SSL 3.0	TLS 1.3
Key Difference	Older protocol with known vulnerabilities.	Newer protocol with better security features.

2. What is HTTPS?

HTTPS (Hypertext Transfer Protocol Secure) is the secure version of HTTP. It uses SSL/TLS to encrypt data between the client (browser) and server. It ensures confidentiality, integrity and authentication while communicating over the web.

3. Define IPsec.

IPsec (Internet Protocol Security) is a suite of protocols that secures IP communications by authenticating and encrypting each IP packet. It operates at the network layer and is used for VPNs and secure communication.

4. What is SSH?

SSH (Secure Shell) is a cryptographic network protocol that provides secure remote login and command execution over an unsecured network. It also supports secure file transfer and tunneling.

5. What is DNS Security?

DNS Security refers to protecting the Domain Name System from attacks such as cache poisoning, spoofing and data tampering. It ensures the integrity, confidentiality and availability of DNS services.

6. What is Phishing?

Phishing is a social engineering attack where an attacker pretends to be a trusted entity (e.g., bank, email service) to trick users into revealing sensitive information like usernames, passwords or credit card details.

7. Define SQL Injection.

SQL Injection is an attack in which an attacker inserts malicious SQL code into input fields of a web application to manipulate the database. It can be used to view, modify or delete data.

8. What is Cross Site Scripting (XSS)?

XSS is a vulnerability that allows an attacker to inject malicious scripts into web pages viewed by other users. These scripts execute in the victim's browser and can steal cookies, session tokens or redirect users.

9. What is Session Hijacking?

Session Hijacking is an attack where an attacker takes over a valid user session by stealing the session ID or token. This allows the attacker to impersonate the user and perform unauthorized actions.

10. Define Firewall.

A Firewall is a security system that monitors and controls incoming and outgoing network traffic based on predefined security rules. It acts as a barrier between a trusted internal network and untrusted external networks.

11. Types of Firewalls.

- Packet Filtering Firewall
- Stateful Inspection Firewall
- Circuit Level Gateway
- Application Level Gateway (Proxy Firewall)
- Next Generation Firewall (NGFW)

12. What is Intrusion Detection System (IDS)?

An Intrusion Detection System (IDS) is a security system that monitors network or system activities for malicious activities or policy violations and alerts the administrator. It does not block attacks but detects and reports them.

Types of IDS:

- Network-based IDS (NIDS)
- Host-based IDS (HIDS)

13. Difference between Stateless and Stateful Firewall.

Feature	Stateless Firewall	Stateful Firewall
Inspection	Checks each packet independently.	Tracks the state of connections.
Information Used	Uses only layer 3, 4 info (IP, Port, Protocol).	Uses full connection information.
Decision Basis	Based on rules applied to individual packets.	Based on the state of active connections.
Security	Less secure.	More secure.
Performance	Faster.	Slower (due to state tracking).
Example	Packet Filtering Firewall	Stateful Inspection Firewall

1. Explain Race Condition :

A race condition occurs when two or more processes or threads access and manipulate shared data simultaneously, and the outcome depends on the timing or sequence of their execution.

This can lead to inconsistent or unexpected results.

Example :

Two threads try to update the value of a shared variable (e.g., counter). If both read the value 10, increment by 1, and write back, the final value may be 11 instead of 12.

Solution : Use synchronization mechanisms like mutex, semaphores, locks to control access to shared data.

2. Explain Access Control Problems :

Access control problems arise when mechanisms that are supposed to restrict or regulate access to resources fail or are misconfigured, allowing unauthorized access.

Common problem :

1. Weak or default passwords.
2. Improper permission settings.
3. Overly permissive access rights.
4. Privilege escalation (getting more rights than allowed).
5. Lack of user authentication or session management.

Impact : Unauthorized users can read, modify, delete or steal sensitive data, or perform operations not allowed to them.

3. Difference between SSL and TLS :

Feature	SSL (Secure Sockets Layer)	TLS (Transport Layer Security)
Full Form	Secure Sockets Layer	Transport Layer Security
Developed by	Netscape	IETF
Purpose	To provide secure communication over a network.	To provide secure communication over a network (improved SSL).
Security	Less secure (older protocol).	More secure and stronger.
Current Status	Deprecated	Widely used
Latest Version	SSL 3.0 (obsolete)	TLS 1.3 (current)
Port Used	Uses port 443 (HTTPS)	Uses port 443 (HTTPS)
Handshake	Less efficient, vulnerable.	More secure and optimized.
Algorithms	Older, weaker algorithms.	Stronger and modern algorithms.

4. Explain DNS Security :

DNS (Domain Name System) security refers to protecting the DNS infrastructure and data from attacks and unauthorized modifications.

Why needed : DNS is critical for translating domain names to IP addresses. If DNS is compromised, attackers can redirect users to fake websites or disrupt services.

Common threats :

- Cache poisoning
- DNS spoofing
- DNS hijacking
- DDoS attacks on DNS servers

Security Measures :

1. Use DNSSEC (DNS Security Extensions) to ensure data integrity and authenticity.
2. Use secure and trusted DNS servers.
3. Restrict zone transfers.
4. Monitor DNS traffic.
5. Use encryption (DoT/DoH).

1. What is Phishing ?

Phishing is a type of social engineering attack in which an attacker tricks users into revealing sensitive information such as usernames, passwords, credit card details, or bank information by pretending to be a trustworthy entity (e.g., bank, email service, website).

How it works :

→ Attacker sends fake emails/messages or creates fake websites.

→ User is lured to click a link and provide information.

→ Attacker captures the information and misuses it.

Example : A fake email claiming to be from a bank asks you to verify your account details through a link. The link opens a fake login page that steals your credentials.

2. Session Hijacking :

Session hijacking is an attack where an attacker takes over a valid user session by stealing the session ID (token) and uses it to impersonate the user.

How it works :

→ User logs in to a website and gets a session ID (stored in cookie or URL).

→ Attacker steals this session ID (using sniffing, malware, XSS, etc.).

→ Attacker uses the stolen session ID to access the user's account.

→ User remains unaware while attacker performs actions.

Prevention : Use HTTPS, secure cookies (HttpOnly, Secure flags), session timeout, and regenerate session ID after login.

3. Cookies :

A cookie is a small piece of data stored by the web server in the user's browser to remember information about the user between multiple requests.

Uses :

- Maintains user session (e.g., login status).
- Stores user preferences (e.g., theme, language).
- Tracks user behavior for analytics and advertising.

Types :

- Session Cookies — Temporary, deleted when the browser is closed.
- Persistent Cookies — Stored for a specified time even after the browser is closed.

Example : When you log in to a website, a cookie stores your session ID so you don't have to login again on every page.

Note : Cookies can be misused if not secured (e.g., session hijacking).

4. Hash Function :

A hash function is a mathematical function that takes input data of any size and produces a fixed-size hash value (digest). It is a one-way function, i.e., it is easy to compute the hash from data, but difficult (or impossible) to get the original data from the hash.

Properties of a Good Hash Function :

- Takes input of any size.
- Produces fixed-size output.
- One-way function (pre-image resistance).
- Small change in input produces large change in hash (avalanche effect).
- Collision resistant (hard to find two inputs with same hash).

Examples : MD5, SHA-1, SHA-256, SHA-3.

Uses : Data integrity, password storage, digital signatures, blockchain, file verification, etc.

Explain HTTPS and SSH

1. HTTPS (Hypertext Transfer Protocol Secure)

HTTPS is the secure version of HTTP. It is used to protect the communication between a web browser (the client) and a web server.

Primary Function: Ensuring that data transferred over the web (like credit card numbers, passwords, or personal messages) remains private and authentic.

Mechanism: It wraps HTTP traffic inside a TLS/SSL (Transport Layer Security) tunnel.

The Layer: It operates at the **Application Layer** (Layer 7).

How it works: When you visit an "https://" website, the browser and server perform a TLS handshake to exchange keys. Once the encrypted tunnel is established, all your requests (like GET or POST) are sent through that tunnel, meaning even if an attacker sniffs your network traffic, they will only see scrambled ciphertext.

2. SSH (Secure Shell): SSH is a cryptographic network protocol used for secure remote login and command-line execution. It is the standard tool for system administrators to manage servers over an insecure network.

Explain Intrusion Detection System (IDS)

An **Intrusion Detection System (IDS)** is a security software or hardware tool designed to monitor network traffic or system activities for malicious activity or policy violations. Think of it as a "security camera" for your network—it records and reports suspicious events, but it does not actively block the traffic itself.

Types of IDS- 1. Network-based IDS (NIDS): NIDS are placed at strategic points within the network to monitor traffic from all devices. They inspect the entire network segment for suspicious packets. **Visibility:** Sees everything on network.

Limitation: Cannot inspect encrypted traffic (e.g., HTTPS/TLS) unless the NIDS has access to the decryption keys, which is often difficult to manage.

2. Host-based IDS (HIDS): HIDS are installed on individual endpoints (servers, workstations). They monitor the internal activities of that specific host, such as system call logs, file modifications, and registry changes.

Visibility: Can see what is happening *inside* the system, even if the traffic is encrypted on the network. **Limitation:** Only protects the host it is installed on; it cannot monitor other devices in the network.

3. DOM-based XSS: This occurs entirely in the client-side code. The vulnerability exists in the JavaScript that processes data from the DOM (Document Object Model) rather than the server-side code.

Example: A page uses JavaScript to read a parameter from the URL and writes it directly into the page using `innerHTML`. If an attacker manipulates the URL, they can force the JavaScript to execute malicious code.

Prevention Strategies

To defend against XSS, you must treat all user-supplied data as untrusted.

Output Encoding: This is the most effective defense. Convert special characters into their safe HTML entity equivalents before rendering them in the browser. For example, `<` becomes `<` and `>` becomes `>`. The browser will display the characters rather than executing them as code.

Input Validation: Implement strict allow-lists for user input. If a field expects an age, only allow integers. If it expects a username, only allow alphanumeric characters.

Content Security Policy (CSP): CSP is an HTTP response header that tells the browser which sources of content (scripts, styles, images) are trusted. By restricting script execution to your own domain and preventing "inline" scripts, you can neutralize most XSS attacks even if an injection vulnerability exists.

Use Modern Frameworks: Modern frontend frameworks (like React, Angular, or Vue) provide built-in protection against XSS by automatically encoding data rendered in the DOM.

1. Define Hash Function.
- A hash function is a mathematical function that takes input data of any size and produces a fixed-size hash value (digest). It is one-way, i.e., it is easy to compute hash, but hard to reverse.
2. List properties of a good hash function.
- It should accept input of any length.
 - It should produce fixed-size output.
 - It should be easy to compute.
 - It should be computationally infeasible to find the original input from the hash value.
 - It should be infeasible to find two different inputs having the same hash (collision resistant).
 - It should be deterministic (same input gives same hash).
 - Small change in input should produce a completely different hash.
3. What is SHA?
- SHA (Secure Hash Algorithm) is a family of cryptographic hash functions designed by NIST (e.g., SHA-1, SHA-256, SHA-512). It is used to ensure data integrity.
4. What is Message Authentication Code (MAC)?
- A MAC is a short fixed-size value generated from a message and a secret key using a hash function. It is used to verify the integrity and authenticity of the message.
5. Difference between Hash and Encryption.
- | Feature | Hash | Encryption |
|---------|------------------------|--------------------------|
| Purpose | Ensures data integrity | Ensures confidentiality |
| Input | Any size | Any size |
| Output | Fixed-size hash value | Variable-size ciphertext |
| Process | One-way (irreversible) | Two-way (reversible) |
| Key | No key required | Key required |
| Example | SHA-256, MD5 | AES, DES, RSA |
6. Define Digital Signature.
- A digital signature is a mathematical technique used to verify the authenticity, integrity and non-repudiation of a digital message using the sender's private key and the sender's public key.
7. What is Authentication?
- Authentication is the process of verifying the identity of a user, device or system before granting access to resources.
8. What is a DoS attack?
- A DoS (Denial of Service) attack is an attempt by an attacker to make a system or network resource unavailable to legitimate users by overwhelming it with excessive requests or traffic.
9. Define Buffer Overflow.
- Buffer Overflow is a vulnerability that occurs when a program writes more data to a buffer than it can hold, causing the extra data to overwrite adjacent memory locations, leading to crashes or malicious code execution.
10. What is Spoofing?
- Spoofing is an attack in which an attacker masquerades as a legitimate entity by forging the source identity (such as IP address, email or MAC address) to gain unauthorized access or trust.

11. What is SSL?
- SSL (Secure Sockets Layer) is a cryptographic protocol that provides secure communication over a network by ensuring confidentiality, integrity and authentication between client and server.
12. Difference between SSL and TLS.
- | Feature | SSL | TLS |
|----------------|------------------------------|--------------------------|
| Full Form | Secure Sockets Layer | Transport Layer Security |
| Developed by | Netscape | IETF |
| Security | Less secure (older protocol) | More secure |
| Current Status | Deprecated | Widely used |
| Latest Version | SSL 3.0 | TLS 1.3 |
13. What is HTTPS?
- HTTPS (Hypertext Transfer Protocol Secure) is the secure version of HTTP. It uses SSL/TLS to encrypt data between the client and server, ensuring secure and trusted communication.
14. Define IPsec.
- IPsec (Internet Protocol Security) is a suite of protocols that secures IP communications by authenticating and encrypting each IP packet of a communication session. It operates at the network layer.
15. What is SSH?
- SSH (Secure Shell) is a cryptographic network protocol that provides secure remote login and command execution over an unsecured network.
16. What is DNS Security?
- DNS Security refers to protecting the Domain Name System from attacks such as cache poisoning, spoofing and data tampering. It ensures the integrity, confidentiality and availability of DNS services.
17. Define Sniffing attack.
- Sniffing is a passive attack in which an attacker intercepts and monitors network traffic to steal sensitive information such as passwords, emails or data.
18. What are Race Conditions?
- Race Conditions occur when two or more processes or threads access and manipulate shared data simultaneously, and the result depends on the timing or sequence of their execution, leading to unpredictable outcomes.
19. What is SSL?
- SSL (Secure Sockets Layer) is a cryptographic protocol that provides secure communication over a network by ensuring confidentiality, integrity and authentication between client and server.

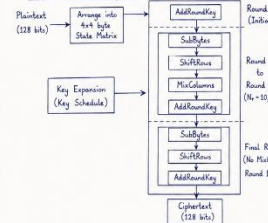
Feature	Active Attacks	Passive Attacks
Definition	Attacks in which the attacker modifies, alters, disrupts or destroys data or resources.	Attacks in which the attacker only monitors or observes the data without changing it.
Goal	To change the system or resources.	To obtain information from the system.
Examples	DoS, Malware, Data modification, Spoofing.	Sniffing, Traffic analysis, Eavesdropping.
Detectability	Easier to detect.	Difficult to detect.
Impact	Affects system performance and resources.	No direct impact on system performance.

1. Difference between Active and Passive Attacks :
2. Types of Malicious Software :
- (a) Virus :
- A virus is a malicious program that attaches itself to a host file or program.
 - It replicates when the infected file is executed and spreads to other files.
 - Example : File infector virus, Boot sector virus.
- (b) Worm :
- A worm is a standalone malicious program.
 - It does not need a host file.
 - It replicates itself and spreads automatically over a network.
 - Example : Conficker, Code Red.
- (c) Trojan Horse :
- A Trojan Horse appears to be a normal and useful program but performs malicious activities in the background.
 - It does not replicate itself.
 - Example : Back Office, Netbus.

1. AES (Advanced Encryption Standard)

AES is a symmetric block cipher adopted by NIST in 2001. It works on 128-bit block of data with key sizes 128, 192 or 256 bits and has 10, 12 or 14 rounds respectively.

A. AES Structure (Encryption)



B. AES Transformations (Steps)

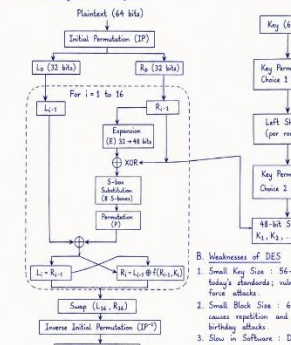
1. AddRoundKey : Performs XOR between the state matrix and round key.
2. SubBytes : Each byte of the state is substituted using an S-box (non-linear transformation).
3. ShiftRows : Cyclically shifts the rows of the state matrix by 1, 2, 3, and 4 bytes respectively.
4. MixColumns : Each column is mixed using fixed mathematical operation over GF(2⁸). (Not in final round).
5. Key Expansion : The original key is expanded to generate round keys for all rounds.

Note : Decryption uses inverse transformations in reverse order: InverseShiftRows → InverseSubBytes → InverseAddRoundKey → InverseMixColumns.

2. DES (Data Encryption Standard)

DES is a symmetric block cipher developed by IBM and adopted as a standard in 1977. It uses 64-bit block size and 56-bit key (8 bits are parity bits). It has 16 rounds of encryption.

A. DES Algorithm (Encryption)



Working of one round: $F(R_{i-1}, K_i) \oplus L_{i-1}$ and L_{i-1} become R_i and L_i respectively. Where, E = Expansion (32 to 48 bits), S = Substitution using 8 S-boxes, P = Permutation (32 bits).

3. Difference : Hash vs Encryption

Feature	Hash	Encryption
Purpose	Ensures data integrity	Ensures confidentiality
Input	Any size of data	Any size of data
Output	Fixed-size hash value (digest)	Variable-size ciphertext
Process	One-way (irreversible)	Two-way (reversible)
Key	No key is required	Key is required
Main Use	Data integrity, password storage, digital signatures	Confidentiality, secure communication
Examples	MD5, SHA-1, SHA-256	AES, DES, RSA

4. Explain DES :

DES (Data Encryption Standard) is a symmetric key block cipher developed by IBM in 1977 and adopted as a standard by NIST. Key Points :

- It uses a 56-bit key (64 bits including 8 parity bits).
- It encrypts data in 64-bit blocks.
- It is based on the Feistel structure.
- It has 16 rounds of encryption.
- Each round uses permutation, substitution (S-boxes), XOR and key mixing.

Working :

Plaintext (64 bits) → Initial Permutation (IP) → 16 Rounds (Feistel Structure) → Final Permutation (FP) → Ciphertext (64 bits)

Note : DES is now considered weak due to its small key size (56 bits) and is replaced by 3DES and AES.

Primary Function: Providing a secure, encrypted channel to interact with a remote computer's shell (command line) or to transfer files securely (via SFTP/SCP). **Mechanism:** It uses a client-server architecture where both sides authenticate each other using cryptographic keys.

The Layer: It operates at the **Application Layer** (Layer 7), but it is specifically designed to provide a secure transport for other applications.

Key Features:

- Remote Access:** You can run commands on a remote server as if you were sitting right in front of it.
- Tunneling (Port Forwarding):** SSH can "tunnel" other insecure protocols inside its encrypted connection. For example, if you have a database server that doesn't support encryption, you can tunnel its traffic through an SSH connection to make it secure.
- Authentication:** SSH supports password-based authentication, but it is highly recommended to use **Public-Key Authentication** (a pair of keys: a private key on your machine and a public key on the server).

Detection Methods

Signature-Based Detection: Similar to an antivirus, this method compares traffic against a database of known attack "signatures" (patterns). **Pros:** Very accurate for known threats. **Cons:** Cannot detect "Zero-Day" attacks or new, unknown malicious patterns.

Anomaly-Based Detection: This method creates a baseline of "normal" network or system behavior using machine learning. If activity deviates significantly from this baseline (e.g., a server suddenly sending 1GB of data to an unknown foreign IP), it triggers an alert.

Pros: Can detect new, unknown threats. **Cons:** Higher rate of "false positives" (flagging normal, legitimate behavior as an attack).

IDS vs. IPS: It is common to confuse an IDS with an IPS (Intrusion Prevention System).

Feature	IDS (Detection)	IPS (Prevention)
Primary Action	Monitors and Alerts	Monitors, Alerts, and Blocks
Positioning	Often "out-of-band" (copy of traffic)	"In-line" (traffic must pass through)
Network Impact	Low (does not delay traffic)	Higher (can introduce latency)

Explain Cross Site Scripting (XSS)

Cross-Site Scripting (XSS) is a security vulnerability typically found in web applications where an attacker injects malicious client-side scripts (usually JavaScript) into web pages viewed by other users.

Unlike SQL Injection, which targets the database, XSS targets the users of the application. By injecting code, the attacker can hijack user sessions, steal cookies, deface websites, or redirect users to malicious domains.

How XSS Works: The attack succeeds because the web browser assumes that any script coming from the application's own server is "trusted." When the browser receives the malicious script along with the legitimate page content, it executes the script within the context of the user's session.

Types of XSS: There are three main variants of XSS, categorized by how the malicious script is delivered:

1. **Stored (Persistent) XSS:** This is the most dangerous form. The malicious script is permanently stored on the target server (e.g., in a database, a comment field, or a user profile). Every time a user views compromised page, script executes.
2. **Reflected (Non-Persistent) XSS:** The script is "reflected" off a web application to the user. It is usually delivered via a link (e.g., in an email or a chat message). script is not stored on the server; it is part of request (often in URL parameters).
3. **Example:** An attacker sends a link to a victim: `https://bank.com/search?q=script>alert('Hacked')</script>`. If the search page displays the query back to the user without sanitizing it, the script runs in the user's browser.